Saudi GRC Platform

Product Blueprint

Source: `product-blueprint.md`

01 — Executive Product Blueprint

Platform: TSS GRC Platform **Version surveyed:** `feat/pdpl-extensions` (HEAD `c6f116f`, 2026-05-11)
Owner: TSS / Anthropic implementation **Scope of this document:** the platform as built and deployable.

---

1. Platform purpose

TSS GRC is a bilingual (Arabic-primary / English) multi-tenant **enterprise Governance, Risk and Compliance platform** purpose-built for Saudi Arabia and the wider MENA market.

It consolidates into one product the workflows a Saudi regulated entity must operate to meet NCA cybersecurity controls, SDAIA / PDPL privacy rules, SAMA operational-resilience expectations, ISO 22301 / 27001 / 31000 / 37301 best practice, and the National Risk Council's resilience agenda. The platform covers risk identification, treatment and acceptance; business continuity and crisis activation; supplier resilience including fourth-party depth; cyber control assessment and incident response; personal-data lifecycle from intake to disposal; and the cross-cutting workflows of evidence, attestation, digital signature, board reporting and corrective actions.

2. Saudi market positioning

Dimension	Position
Geography	Saudi-first; designed for Riyadh / Jeddah / Khobar operational regions. UTC+3, Hijri calendar surfacing alongside Gregorian.
Language	Arabic primary; English secondary. Every user-visible entity carries *_ar and *_en columns. RTL/LTR auto-switching.
Data residency	Default tenant data stays in Saudi cloud regions; cross-border transfers tracked under PDPL Art. 29.
Frameworks	NCA ECC, CSCC, CCC, OTCC; SAMA Cyber Security Framework; PDPL + SDAIA implementing regulations; SAMA outsourcing rules; ISO 22301, 27001, 31000, 27701 (where applicable), 37301.
Sectors targeted	Banking & finance (SAMA), insurance (SAMA), telco & cloud (NCA + CITC), healthcare (NHIC), critical infrastructure (CNI), and the digital-government estate (DGA / SDAIA).

3. Target customers

Primary:

- Tier-1 Saudi banks and financial institutions (SAMA Cyber + NCA ECC + operational resilience)
- Government entities & digital-government agencies (DGA, SDAIA, NCA scope)
- Critical national infrastructure operators (telco, energy, utilities, healthcare)
- Saudi-listed firms (CMA disclosure + ESG + internal audit needs)

Secondary:

- Large supplier ecosystems serving the Saudi public sector (vendor portal use-case)
- Saudi subsidiaries of GCC and global organisations operating under PDPL

4. Regulatory coverage

Regulator / Standard	Coverage in the platform
NCA — ECC, CSCC, CCC, OTCC	Framework catalogue (V37), control libraries (V42-44), control assessments, filings (V27), cyber-incident management with NCA notification path
SDAIA — PDPL & Implementing Regs	ROPA, privacy notices, consent, DSR, PIA, breach (72h), cross-border transfer, disposal certificate, processor due-diligence
SAMA — Cyber + Outsourcing	SAMA framework seed + control library; supplier risk + resilience; cross-border + processor rules; reporting cadence
ISO 22301 / 31000 / 27001	Mapped under evidence.frameworks, BCM lifecycle, ERM lifecycle, control library
National Risk Council / National Resilience	Critical service identification, BIA, BCP, DR plans, crisis activation, exercises
CMA / Audit	Board reporting, audit workspace, audit lifecycle, evidence chain-of-custody
HRSD (Nitaqat, GOSI, WPS)	HRSD compliance panel + process initiation
MOC	Tasattur, consumer-complaint, CR feed integration

5. Core modules

The platform is a modular Spring Boot monolith. 17 backend modules under `tss-grc-backend/src/main/java/com/tss/grc/module/`:

Module	Headline function
auth	JWT auth, MFA, password / token policies
iam	Users, roles, permissions, org membership, SSO/Nafath
admin	Platform admin: tenants, branding, committee workflows
risk	ERM register, appetite, KRIs, scenarios, emerging risk
bcm	BIA, BCP, exercises, DR plans, crisis management
scm	Vendor register, dependency map, resilience (alternates, exit plans, tests), fourth-party, contract clauses
tprm	Third-party risk programme, onboarding, reassessment, cyber assessment
cyber	Frameworks, controls, assessments, incidents, vulnerabilities, exceptions, assets, RCA
compliance	Frameworks, requirements, controls, attestations, regulatory feed, MOC/HRSD/SAMA panels
privacy	ROPA, notices, consent, DSR, PIA, breach, CBT, disposal, DSA, processor DD, cyber-bridge
evidence	Repository, versions, chain-of-custody (SHA-256), permissions
incident	Incident lifecycle (NIST 800-61), RCA, lessons-learned, CAPA generation
capa	Corrective + preventive action tracker

Module	Headline function
signature	Digital signature transactions, board pack, multi-provider
workflow	Workflow engine + versioning
reporting	Board pack, regulatory packages, scheduled reports, exports
dashboard	Live KPIs, heatmap, widget customisation

Plus the `platform` module (multi-tenant context, audit, realtime broadcaster, notifications).

6. Cross-module integration logic

The platform's distinctive value is **the bridges between modules**. Concrete wired-in integrations as of HEAD:

- **Cyber** → **PDPL** (V46): cyber incidents that touch personal data automatically trigger a PDPL data-breach record + start the 72h timer; full audit trail in `privacy.cyber_breach_bridge_log`.
- **ROPA** → **PDPL workflows** (V32-V34 + V48): each ROPA entry surfaces counters for its linked privacy notices, cross-border transfers and disposal certificates with one-click deep-link.
- **TPRM** → **CAPA** (TprmAutomationService): failed processor due-diligence assessments, HIGH-concentration fourth-party rows, and FAILED resilience tests auto-open a CAPA with the right severity and target date.
- **RCA** → **CAPA** (V31): approved RCA recommendations spawn CAPA tasks with `originType="rca"` traceability.
- **Evidence chain** (V47): every evidence version is SHA-256 hashed against the prior version; the chain is independently verifiable.
- **Workflow signatures** (V30): any workflow approval can require a cryptographic digital signature; provider-pluggable (internal, DocuSign, Absher, Nafath).
- **Realtime broadcaster**: 13 lifecycle services emit `changed.*` events over STOMP/WebSocket so dashboards and detail pages refresh live.

7. Licensing model

The product is positioned for **annual SaaS subscription** with a per-organisation tier and optional add-ons:

Tier	Includes
Core	ERM, BCM, Compliance, Evidence, Reporting, Bilingual UI
Saudi Regulatory Pack	NCA frameworks + filing, PDPL extensions, SAMA pack, HRSD/MOC panels
Resilience Pack	Supply chain, fourth-party, alternate / exit / resilience-tests, DR plans, crisis room
Cyber Add-on	Cyber controls, incidents, vulnerabilities, OT/ICS (OTCC), Cloud (CCC), SOC integrations
Privacy Add-on	Full PDPL: ROPA + notices + consent + DSR + PIA + breach + CBT + disposal + DSA + processor DD
Premium	Board Pack PDF/PPTX, advanced realtime, white-label, scheduled reports, advanced workflow engine

Multi-tenant: a customer typically buys at the **organisation** level; sub-organisations (group entities) get full data isolation under a single platform tenant.

8. Key differentiators

1. **Saudi-native, not localised after the fact.** Frameworks (NCA suite + SAMA + PDPL) are first-class; the data model has Arabic from row one.
2. **Cross-module automation is wired, not aspirational.** A FAILED Art. 28 processor assessment automatically opens a CAPA; a cyber incident touching PII automatically files a PDPL breach with a 72h timer.
3. **Bilingual data, not bilingual labels.** Every business object carries `_ar` and `_en` columns and shows the operator's chosen language.
4. **Saudi-business Arabic, not literal MSA translations.** Heat-map labels, workflow names, evidence-pack titles use the phrasing a SAMA inspector or audit-committee chair actually uses.
5. **Operator-graded controls.** NCA ECC 30, CSCC 32, CCC 30, OTCC 27, SAMA 8, ISO 22301 8, PCI DSS 8 — 145 controls with bilingual procedure text and maturity tiers shipped at install.
6. **One platform, not a portfolio.** ERM + BCM + cyber + privacy + supply chain + audit + evidence + reporting all in one schema, one auth, one notification stream — no inter-module ETL.

9. Product maturity roadmap

Phase	Status	Sprints	Highlights
Sprint 1 — Foundation	✓ DONE	sprints/sprint-1.md	Auth, IAM, Risk, BCM, Compliance, Evidence base, bilingual shell
Sprint 2 — Vertical depth	✓ DONE	sprints/sprint-2.md	Cyber, Incidents, TPRM, SCM, Audit
Sprint 3 — Saudi regulator coverage	✓ DONE	sprints/sprint-3.md	NCA ECC + filing, PDPL + DSR + PIA + breach, HRSD/MOC/SAMA panels
Sprint 4 — Convergence	✓ DONE	sprints/sprint-4-convergence.md	Workflow engine, realtime, board pack, attestation, regulatory feed
Sprint 5 — Gap closure	✓ DONE	(this doc set)	Digital signature, RCA, scenarios, emerging risk, IT DRP, committees, contract clauses, alt suppliers + exit, NCA suite (CSCC/CCC/OTCC), PDPL extensions (CBT, disposal, notice), evidence chain-of-custody, cyber→PDPL bridge
Sprint 6 — TPRM depth	✓ DONE	(this doc set)	Fourth-party exposure, DSA, processor DD, third-party cyber, supplier resilience tests, consolidated TPRM overview, dashboard surfacing, cross-module automation

Phase	Status	Sprints	Highlights
Next: Sprint 7 — Operate	planned	TBD	OT/ICS deep-dive (Saudi industrial sector), SAMA outsourcing portal, AI governance, ESG/Vision-2030 alignment, advanced analytics

Cross-references

Topic	See
Per-module architecture	/02-Module-Architecture/
Workflow catalogue	/03-Workflow-Catalogue/
Data model	/04-Data-Model/
Regulatory mapping	/07-Regulatory-Mapping/
Gap analysis	docs/saudi-grc-gap-analysis.md
Module status snapshot	STATUS.md
Repo-level overview	README.md